

# D3-FI 资金安全修复与二次全方位复检报告

白盒审计 · 多 Agent 并行修复 · 对抗性复检 · 线上库实测验证

项目:D3-FI-UI(Supabase Edge Functions / Deno + BSC 链上合约 + React)

分支: security/fund-safety-remediation (已推送 origin,13 个安全提交)

日期:2026-07-16 · 阶段:未上线 · 结算币:测试/水龙头币(fake USDT)

范围:认证/授权、内部账本、质押、收益/D3 价格、奖励分配、闪兑、金库/Turnkey、后台、数据库、任务调度、合约、基础设施

最终判定:CONDITIONAL(代码层 P0/P1 全部关闭并部署;剩余为部署/运维待办)

25+3

识别漏洞(V-01...V-25 +  
NEW-1/2/3)

110

安全回归测试全通过

11

数据库迁移已上线部署

0

anon 可直接读写的资金表(实测  
401)

## 一、执行摘要

首轮白盒审计判定系统不可承载真实资金(NO):存在匿名冒充任意钱包盗取全部余额、公开 anon key 直改数据库价格/伪造多签、Turnkey 可签任意交易、闪兑并发双花、假币可接入会计等多个致命缺陷。

本次以"固定跨 Agent 契约 + 文件不重叠"的方式,分三轮共 12 个并行 Agent 完成修复,并进行了两轮对抗性复检(复检又发现 4 个修复引入/遗漏的高中危问题,已全部再修复)。全部代码可修项已关闭、测试覆盖(110 项)、并用 access token 将数据库修复实际部署到线上库且逐条验证。

当前处于未上线、使用测试/水龙头币阶段,测试期真实资金敞口可控。转为可承载真实资金前,需完成"部署/运维检查清单"(第六节)中的链上与凭证隔离事项。综合判定:CONDITIONAL。

## 二、修复与部署总览

| ID    | 漏洞                                   | 严重度      | 最终状态        | 关键修复 / 证据                                                              |
|-------|--------------------------------------|----------|-------------|------------------------------------------------------------------------|
| V-01  | 认证形同虚设:header 钱包未绑定 JWT;treasury 无认证 | Critical | 已关闭         | 新增 requireActorWallet 绑定 Privy sub;全 20+ 路由改造;treasury 补认证             |
| V-01+ | 修复引入:首次绑定(TOFU)账户劫持                  | High     | 已关闭         | 绑定前经 Privy API 校验钱包属该用户;已绑走快路径;失败即拒                                    |
| V-19  | 14 张资金表未启用 RLS,anon 可直接写             | Critical | 已关闭·已部署     | 迁移 031;实测 anon 读/改价/伪造签名均 401                                          |
| V-02  | Turnkey 策略允许签任意交易                    | Critical | 代码已关闭 需执行策略 | 改为 USDT-transfer/gas/兜底 DENY 限定策略;需运行 npm run turnkey:policies         |
| V-03  | 闪兑先付后扣 + 并发双花                        | Critical | 已关闭         | 请求时原子扣减(RPC)+ 在途唯一索引 + 失败回补;移除 sweep 二次扣减                              |
| V-05  | D3 价格单行可改、无边界/预言机                    | Critical | 已关闭·已部署     | 边界/偏差/时效护栏;失效即拒付(迁移 035 列已上线)                                          |
| V-20  | 水龙头币可接入生产会计                          | Critical | 已关闭         | assertSettlementTokenSafe();测试期经显式 ALLOW_MAINNET_FAUCET_TOKEN 放行,上线前移除 |
| V-04  | 边缘环境持过大凭证,单机被攻破=全平台                  | Critical | 部署待办        | V-02 已缩小爆炸半径;仍需签名服务隔离 + root quorum≥2 + 移除金库 quorum key                |
| V-06  | UD3 余额/转账非原子扣减                       | High     | 已关闭·已部署     | 迁移 034 原子 debit_ud3_balance / transfer_ud3                             |
| NEW-1 | 复检发现:原子借记 vs 非原子贷记的丢失更新双花            | High     | 已关闭·已部署     | 迁移 041 credit_ud3_balance ;结算/奖励/收益贷记全改原子 RPC                          |
| NEW-2 | 复检发现:慢确认交易的退款导致双重支付                  | High     | 已关闭         | 仅未广播才自动退款;已广播转 manual_review ;+确认深度检查                                  |

|         |                                  |      |             |                                                                       |
|---------|----------------------------------|------|-------------|-----------------------------------------------------------------------|
| V-21    | 充值 report-tx 重放双记业绩/账目           | High | 已关闭·已部署     | 入口守卫 + 原子跃迁门控;ledger 幂等唯一索引(033)                                      |
| V-22    | 推荐合约全部角色集中于单一热 EOA               | High | 部署待办        | 需将 UPGRADER/REBIND/ADMIN 转多签并 renounce 热 EOA;加 timelock               |
| V-08    | 后台无审计/无 maker-checker(+2 残留)     | High | 已关闭·已部署     | 迁移 040 审批表;每次改动 before/after 审计;付款类改动双人复核;先锁后执行防 TOCTOU               |
| V-09/10 | 闪兑/金库无限额、无 solvency 门禁、无熔断       | High | 已关闭·已部署     | 迁移 038 限额表 + 熔断开关;扣减前 <code>assertWithdrawAllowed</code> (单笔/日/时/偿付率) |
| V-11    | settlementDate 无上限,未来日期铸收益       | Med  | 已关闭         | 拒绝 > 今日(SGT)                                                          |
| V-23    | 账户余额列无 CHECK≥0                   | High | 已关闭·已部署     | 迁移 032:10 个余额列非负约束                                                    |
| V-24    | 审计日志可被改删;cron secret 明文入 pg_cron | Med  | 代码已关闭 密钥待轮换 | 迁移 036 禁改删规则;cron secret 轮换为部署待办                                      |
| V-25/18 | 归集无原子认领;付款无确认深度;reorg            | Med  | 主体已关闭       | 原子认领 <code>queued→signing</code> ;付款 ≥12 确认;充值 reorg 全回滚为路线图          |
| V-14    | cron secret 非常量时间比较              | Med  | 已关闭         | <code>timingSafeEqual</code>                                          |
| V-15    | 金额输入校验缺失(Infinity/负/科学计数)        | Med  | 已关闭         | <code>assertMoneyAmount</code> 覆盖全部资金路由                               |
| V-16    | 无速率限制                            | Med  | 已关闭·已部署     | 迁移 039 + 高风险路由限流;限流器 fail-open(有 V-09 兜底,已监控)                         |
| V-17    | demo 模式默认开(fail-open)            | Low  | 已关闭         | 仅 <code>DEMO_MODE_ENABLED='true'</code> 才开                            |
| V-07    | 推荐可自荐(无 DB 约束)                   | Med  | 已关闭·已部署     | 迁移 037 自荐 CHECK                                                       |
| V-12    | 金融金额用 JS 浮点                      | Low  | 已接受·路线图     | 链上量用 wei/bigint;账本列漂移受四舍五入界定;计划迁 integer/numeric                      |
| V-13    | 赎回信任可变量而非账本                      | Med  | 主体已缓解       | 原子扣减 + 幂等去重;全账本重算为路线图                                                 |
| NEW-3   | 限流器 fail-open                    | Low  | 已接受·监控      | 由原子扣减 + 在途索引 + V-09 限额兜底;仅节流在限流器故障时短暂失效                               |

三、数据库修复:线上库实际部署与验证结果

按你的授权,使用 `SUPABASE_ACCESS_TOKEN` 经 Supabase Management API 将迁移 031—041 实际应用到线上库(以 `postgres` 超级用户执行),并逐条验证:

| 验证项                         | 期望 | 线上实测结果                                                                           |
|-----------------------------|----|----------------------------------------------------------------------------------|
| 14 张暴露表启用 RLS               | 14 | 14 / 14 ✓                                                                        |
| anon 角色表/序列/函数授权清零          | 0  | 0 剩余 ✓                                                                           |
| 原子余额 RPC(security definer)  | 5  | debit/credit_pending_d3_yield、debit/credit_ud3_balance、transfer_ud3 = 5 ✓        |
| 余额非负 CHECK 约束               | 10 | 10 / 10 ✓                                                                        |
| D3 价格护栏列                    | 5  | 5 / 5 ✓                                                                          |
| 审计不可变规则(禁 update/delete)    | 2  | 2 / 2 ✓                                                                          |
| 幂等索引(闪兑在途 + ledger 去重)      | 2  | 2 / 2 ✓                                                                          |
| 风控表 + 熔断开关 + 限流 RPC + 后台审批表 | 存在 | risk_limits、system_pause_flags(5 行)、rate_limit_hits+RPC、admin_action_approvals ✓ |

实测渗透验证(V-19 关闭证据)

用浏览器可见的 anon/publishable key 直连 PostgREST 尝试攻击此前"全开"的资金表:

```
READ d3_price_settings -> 401 permission denied for table d3_price_settings (42501)
WRITE d3_price_settings -> 401 permission denied (改价失败)
WRITE multisig_signatures -> 401 permission denied (伪造多签失败)
```

修复前这些操作可直接成功(可改 D3 价格套现、可伪造多签放行分红);修复后全部被拒。

四、三轮修复与两轮复检概览

- 第一轮(6 Agent):V-01 认证绑定、V-19 RLS 锁定、V-02 Turnkey 策略收敛、V-03 闪兑原子化、V-05 价格护栏、V-06 UD3 原子、V-20 假币守卫、V-21 充值幂等,及 V-07/14/15/17/23/24/25 附带项。
- 第二轮(3 Agent,"其他防护做好"):V-09/10 闪兑限额 + 偿付率门禁 + 熔断开关、V-11 结算日期上限、V-16 速率限制、V-08 后台不可变审计 + maker-checker。
- 两轮对抗性复检 → 第三轮(3 Agent):复检发现并修复 —— V-01 TOFU 账户劫持(经 Privy API 证明所有权)、NEW-1 贷记侧丢失更新双花(全改原子 RPC)、NEW-2 慢交易退款双付(退款门控 + 确认深度)、V-08 两处残留(market\_leader 纳入复核、审批先锁后执行防 TOCTOU)。

五、测试与工程结果

- 安全回归测试:110 项全通过(15 个测试文件),覆盖认证绑定/所有权证明、原子借贷记、闪兑退款分支、幂等、限额/熔断、价格护栏、假币守卫、Turnkey 策略构造、后台复核与 TOCTOU。
- 测试框架:vitest + Deno 垫片 + npm: 别名( vitest.security.config.ts ),使 Deno 边缘模块可在 Node 下执行断言。
- 提交:13 个按漏洞主题分组的安全提交,已推送 origin/security/fund-safety-remediation 。
- 局限:两个路由文件( treasury/index.ts 、 union/index.ts )含 Deno https: 传递依赖,无法在 vitest 内导入,仅做静态编辑 —— 需在 CI 用 deno check 做类型校验(本机无 Deno)。资金逻辑核心模块均已运行时测试。

六、上线前部署 / 运维检查清单

- 以下为非代码、需你在链上/控制台/CI 操作的事项。完成后系统即满足承载真实资金的条件。
- 运行 npm run turnkey:policies 使收敛后的 Turnkey 签名策略生效(V-02)。
  - Turnkey:确认 root quorum ≥ 2/3,后端用户单方不足以满足;将金库 cosigner / PRIVY\_TREASURY\_AUTH\_PRIVATE\_KEY 移出边缘函数环境,签名下沉独立服务(V-04)。
  - ReferralRegistry:将 UPGRADER/REBIND/ADMIN 三角色转 Turnkey 多签,renounce 部署热 EOA,UPGRADER 加 timelock(V-22)。
  - 结算币:上线前把 BSC\_USDT\_CONTRACT 钉真实 USDT,并移除 ALLOW\_MAINNET\_FAUCET\_TOKEN (测试期用它放行水龙头币)。
  - 轮换 TREASURY\_CRON\_SECRET ,并将其移出 pg\_cron 作业行明文(改由 Vault/函数密钥注入)(V-24)。
  - 生产设 DEMO\_MODE\_ENABLED 为非 true(V-17 默认已安全)。
  - CI 增加 deno check 覆盖 treasury/index.ts 、 union/index.ts 。
  - 配置监控告警与自动对账(链上充值 vs 内部账本、Swap 钱包偿付率、价格突变、Turnkey/Safe 权限变更);把 system\_pause\_flags 接入运营熔断面板。

已完成(代码 + 线上库)

- 认证绑定 + 钱包所有权证明;treasury 补认证
- 14 表 RLS + anon 清零(线上实测 401)
- 闪兑/UD3/结算/奖励 全链路原子借贷记 + 幂等约束
- 闪兑限额 + 偿付率门禁 + 熔断开关;慢交易退款门控 + 付款确认深度
- D3 价格边界/偏差/时效护栏(失效拒付);假币生产守卫
- 后台不可变审计 + 付款类改动双人复核(先锁后执行)
- 余额非负约束、审计不可变、推荐自荐约束、速率限制、金额校验、cron 常量比较

七、上线判定与损失敞口对比

| 维度          | 修复前                     | 修复后(测试期 / 完成部署清单后)            |
|-------------|-------------------------|-------------------------------|
| 可否承载真实资金    | NO                      | CONDITIONAL → 完成第六节后可转 GO     |
| 匿名冒充/盗取全站余额 | 可(header 伪装 + anon 直改库) | 已封堵(所有权证明 + RLS 实测 401)       |
| 闪兑钱包被抽干     | 可(并发双花 + 无限额)           | 已封堵(原子扣减 + 在途唯一 + 限额/偿付率/熔断)  |
| 热钱包被任意签名掏空  | 可(Turnkey 任意交易)         | 代码已收敛,执行策略 + 凭证隔离后关闭(V-02/04) |

|          |               |                                          |
|----------|---------------|------------------------------------------|
| 金库最大损失   | 全部(凭证共环境可自审批) | 需 root quorum $\geq$ 2 + 凭证隔离(部署待办 V-04) |
| 后台单人违规付款 | 可             | 已封堵(maker-checker + 不可变审计)               |

**结论:**本阶段使用测试/水龙头币、未接入真实资金,配合已部署的认证/RLS/原子账本/限额熔断/价格护栏,测试期资金安全达标。 承载真实资金前,请完成第六节的 3 项链上/凭证事项(V-02 执行、V-04 凭证隔离、V-22 合约角色多签)——这三项完成后可转为 GO(允许真实资金)。